

1) Pick any one app you use daily (such as Instagram, Zomato, or PhonePe) and list 5 security measures it likely uses to protect user data.

Answer: Instagram

Instagram is used here as the example application. The following measures are common security measures for a large online service; they are presented as security practices rather than claims about proprietary implementation details.

Security measure	How it helps protect user data
Two-factor authentication (2FA)	Adds an extra verification step when a user signs in, reducing the effect of a stolen password.
Encryption	Protects sensitive information while it is transmitted and, where appropriate, while it is stored.
Access control	Limits what users, employees, and services can access according to their permissions and role.
Security monitoring	Monitors systems and activity for unusual behavior or possible security incidents.
Backups and recovery	Maintains protected copies of important data so information can be restored after incidents or failures.

Verification

- Five security measures are listed with a clear explanation of how each can protect user data.

2) Choose either the NIST Cybersecurity Framework, ISO 27001, or CIS Controls. For each of the 5 security measures you listed in the previous task, map it to the most relevant category or control in your chosen framework.

Chosen framework: NIST Cybersecurity Framework (CSF) 2.0

NIST CSF 2.0 organizes cybersecurity outcomes into six Functions: Govern, Identify, Protect, Detect, Respond, and Recover. The mappings below use the most relevant CSF 2.0 outcome areas.

Security measure	NIST CSF 2.0 mapping	Reason
Two-factor authentication (2FA)	PR.AA — Identity Management, Authentication, and Access Control	Authentication controls help ensure that users, services, and devices are appropriately authenticated.
Encryption	PR.DS — Data Security	The Protect Function includes outcomes for safeguarding data in storage and transit.
Access control	PR.AA — Identity Management, Authentication, and Access Control	This Function covers management and enforcement of identities, permissions, and access.
Security monitoring	DE.CM — Continuous Monitoring	Detect includes continuous monitoring of assets and systems for potentially adverse events.
Backups and recovery	PR.DS — Data Security / RC.RP — Incident Recovery Plan Execution	Protected data copies support resilience, while Recover supports restoration after incidents.

Verification

- The five measures are mapped to NIST CSF 2.0 outcome areas without claiming that the example app publicly discloses its internal controls.

3) Given this scenario: A new food delivery app wants to prevent unauthorized access, protect payment info, and ensure customer privacy. Select 3 controls from the CIS Controls framework that would address these concerns and explain how each control helps.

Framework used: CIS Critical Security Controls v8.1

- Control 5: Account Management: Maintain proper user and service accounts, remove unnecessary accounts, and manage accounts throughout their lifecycle. This reduces unauthorized access through abandoned or unnecessary accounts.
- Control 6: Access Control Management: Manage access permissions according to business need and least privilege. This can limit who or what can access customer and payment-related systems.
- Control 3: Data Protection: Identify, classify, securely handle, retain, and dispose of data. This supports protection of customer personal information and payment-related data throughout its lifecycle.

Verification

- The selected controls address unauthorized access, payment-data protection, and customer privacy.

4) Create a comparison table with three columns (NIST, ISO 27001, CIS Controls) and list 3 unique features or strengths of each framework based on your research.

NIST CSF 2.0	ISO/IEC 27001:2022	CIS Controls v8.1
Uses six Functions: Govern, Identify, Protect, Detect, Respond, Recover.	Defines requirements for an Information Security Management System (ISMS).	Provides a prioritized set of cybersecurity Safeguards and Controls.
Outcome-focused and flexible; it does not prescribe one specific way to achieve each outcome.	Uses a risk-management approach and supports establishing, implementing, maintaining, and continually improving an ISMS.	Provides practical and prescriptive actions intended to address common attack paths and improve cyber hygiene.
Can help organizations assess, prioritize, and communicate cybersecurity risk across different organization sizes and sectors.	Can be used as the basis for formal conformity/certification when an organization chooses that route.	Uses Implementation Groups (IG1, IG2, IG3) to help organizations prioritize safeguards based on risk and resources.

Key difference in simple words

- NIST CSF: organizes and communicates cybersecurity outcomes and risk management.
- ISO/IEC 27001: focuses on building and continually improving a formal ISMS based on risk.
- CIS Controls: focuses on prioritized, practical safeguards that organizations can implement.

5) Use ChatGPT or another AI tool to generate a checklist of 5 security actions a small e-commerce startup should take according to the ISO 27001 framework. Copy the AI's response and briefly comment on whether you agree with each item and why.

AI-Generated Checklist

1. Establish an information security policy.

Comment: Agree. A documented policy gives the startup a clear direction for managing information security and responsibilities.

2. Perform an information security risk assessment.

Comment: Agree. ISO/IEC 27001 uses risk management to identify and treat information-security risks.

3. Manage access rights and user accounts.

Comment: Agree. Controlling access helps ensure that only authorized people receive access to information and systems.

4. Protect information with appropriate technical and organizational controls.

Comment: Agree. The organization should select controls based on its risks and the context of its ISMS, including measures for confidentiality, integrity, and availability.

5. Monitor, review, and continually improve the ISMS.

Comment: Agree. ISO/IEC 27001 is a management-system standard that includes monitoring, review, and continual improvement rather than a one-time security project.

Final Verification

- The checklist contains five actions and a brief comment on each item, as requested.